

SOP FOR PRIVACY OFFICE OPERATIONS

No. BAL/MIS/24-25/084; Date. 31-Jan-2025

This policy establishes
standard privacy
operations at BAL.

Bajaj Auto Limited, hereinafter referred to as “We” or “Us” or “Organization” or “BAL”, has created this document to demonstrate its commitment to maintain privacy of its customers/data subjects by safeguarding their personal data.

Reference			
Version		Status	
1.0		Released	
Author		Audience	
Govind Gopakumar		C2 - Bajaj Auto Restricted	
Version Updates			
Created/Modified By		Date	Version Modified
Name	Designation		
A V Jefferson	Asst. Mgr	31-01-2025	Original
Version History		Summary of Modification	
Policy No			
BAL/MIS/24-25/082			
Department		Date (Latest Update)	
MIS		31-01-2025	
Coverage			

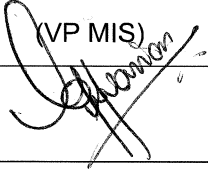
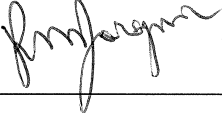
Initiated By	Reviewed By		Approved By
Govind Gopakumar (Asst Mgr MIS)	Sanjay R. Ambadkar (DM MIS)	Badri Narayana Subramaniyan (VP MIS)	Rajeev Jorapur (Head MIS)
			

Table of Contents

1. Objective:	3
2. Overview	3
3. Scope.....	3
4. Policy	Error! Bookmark not defined.
5. Review Frequency	5
6. Annexure	Error! Bookmark not defined.

1. Objective

The objective of this SOP is to establish a standardized approach for managing privacy compliance, ensuring data protection, and aligning with applicable data privacy/protection regulation.

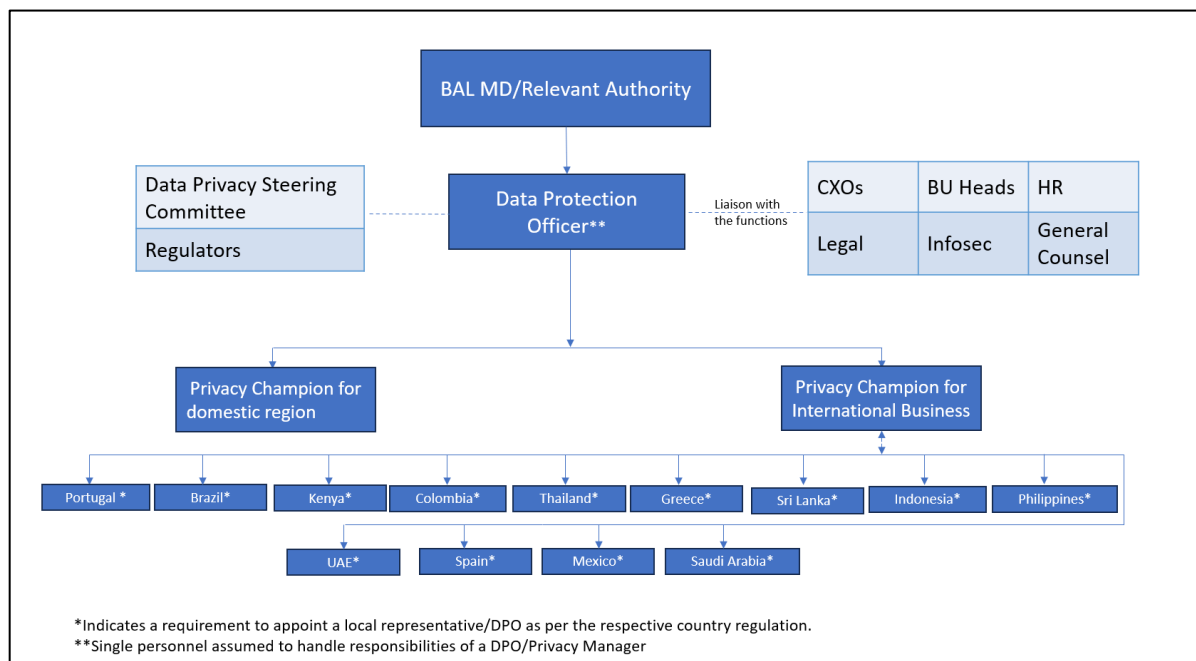
2. Overview

This SOP defines the roles and responsibilities of the stakeholders involved in the Privacy Office operations. It outlines the processes for ensuring privacy compliance in domestic and international operations, as well as how the privacy governance framework will be managed in coordination with the employees and stakeholders involved in the privacy operations.

3. Scope

This document applies to all activities, processes, systems, and personnel involved in the processing of customer personal data related to connected electric vehicles to ensure compliance with applicable data protection laws and regulations in all personal data processing activities across Bangladesh, Brazil, Colombia, Greece, Indonesia, Kenya, Mexico, Nepal, Philippines, Portugal, Saudi Arabia, Spain, Sri Lanka, Thailand, Turkey, UAE.

4. Roles and Responsibilities



Please refer the BAL DPO Org Structure and Roles and Responsibilities (BAL/MIS/24-25/082) document for detailed view of the Data Privacy Office Organization Structure.

5. Privacy Operations

5.1. Privacy Governance and Compliance

- Maintain an updated Privacy Policy and ensure adherence as per the scope of the document.
- Conduct annual privacy assessments or internal audits to assess compliance.
- Review and update Records of Processing Activities (RoPA) regularly.

5.2. Personal Data Inventory Management

- Develop and maintain a centralized Personal Data Inventory (PDI) to track the collection, storage, and processing of personal data.
- Classify data based on sensitivity and regulatory requirements.
- Implement data minimization and retention strategies.
- Ensure mapping of data flows across systems, applications, and third-party vendors.

5.3. Records of Processing Activities (RoPA)

- Maintain an up-to-date inventory of data processing activities.
- Document the purpose, categories of data, retention periods, and legal basis for processing.
- Regularly (at least annually or earlier whichever is applicable) review and update RoPA to reflect changes in data processing.

5.4. Impact Assessments

- Conduct Privacy Impact Assessments/Data Protection Impact Assessments for projects handling personal data.
- Assess potential risks and implement mitigation measures.
- Maintain records of assessments for audit purposes.
- Engage relevant stakeholders, including legal, security, and business units, during the DPIA process.
- Conduct **Transfer Impact Assessments (TIAs)** for international data transfers.
- Evaluate risks associated with data transfers to non-adequate jurisdictions.
- Implement supplementary measures to ensure compliance with cross-border data transfer regulations.

5.5. Data Subject Access Request Handling (DSAR Handling)

- Ensure adherence to BAL Data Subject Rights Management Policy (BAL/MIS/24-25/075) for handling Data Subject Access Requests (DSARs).
- Verify data subjects before fulfilling requests.
- Respond within regulatory timelines (e.g., GDPR: 30 days, CCPA: 45 days).
- Maintain records of all requests and responses as documented in the BAL Data Subjects Rights Management Policy.

5.6. Incident Response and Data Breach Management

- Ensure adherence to the defined BAL Personal Data Breach Notification and Incident Response Procedure (BAL/MIS/24-25/080)
- Report breaches within required timelines (e.g., GDPR: 72 hours).
- Document all incidents, root cause analyses, and corrective actions as per the BAL Personal Data Breach Notification and Incident Response Procedure.
- Conduct post-breach reviews to strengthen security measures.

5.7 Third-Party Risk Management

- Conduct thorough vendor due diligence before onboarding.
- Ensure all vendors handling personal data sign Data Processing Agreements (DPAs) or relevant documentation (as applicable).
- Require vendors to implement industry-standard security controls and compliance measures.
- Conduct regular privacy compliance assessments for third parties.
- Define incident response protocols for vendors, including breach notification requirements.
- Ensure proper data transfer mechanisms are in place for cross-border processing.
- Establish a vendor offboarding process to ensure secure data deletion upon contract termination.

5.8 Training and Awareness

- Conduct mandatory privacy training for all personnel involved in the processing of customer personal data.
- Run awareness campaigns on data protection best practices.
- Provide role-specific training for Privacy Champions, Regional DPOs and personnel involved in processing of customer personal data.

6. Review Frequency

This document is subject to annual review or earlier if there are changes in the business environment or applicable data privacy/protection regulations. Any updates to this document will be recorded at the beginning of the document.

7. Appendix

a. Definitions

- **Data Subject:** A data subject is a natural person whose personal data is collected, stored, or processed.
- **Personal data:** Any information relating to an identified or identifiable natural person. An identifiable natural person is one who can be identified, directly or indirectly, in

particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors.

- **Customer:** A customer is a person who buys goods or services from another business
- **Processing:** Any operation or set of operations which is performed on personal data or on sets of personal data, whether by automated means, such as collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure, or destruction.
- **Cross-Border Transfer:** Cross-border transfer refers to the processing of personal data by a controller or processor operating across multiple jurisdictions where they have establishments.
- **Controller:** Any natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing of Personal data.
- **Processor:** Any means a natural or legal person, public authority, agency, or other body which processes Personal data on behalf of the controller.
- **Third-Party:** A natural or legal person, public authority, agency, or body other than the data subject, controller, processor, and persons who, under the direct authority of the controller or processor, are authorized to process personal data.